Политика информационной безопасности

ООО "Северный Ветер"

1. Общие положения

1.1. Политика устанавливает обязательные требования к защите информации и информационных систем ООО "Северный Ветер". Она распространяется на всех работников, подрядчиков и стажёров.

1.2. Ответственным за исполнение Политики является начальник службы информационной безопасности (далее - начальник службы ИБ). Контактный адрес службы: security@severnyveter.example.

1.3. Незнание требований Политики не освобождает от ответственности. Каждый работник проходит обучение по информационной безопасности при приёме на работу и затем не реже одного раза в 12 месяцев.

2. Классификация информации

2.1. Вся информация Компании делится на три категории: публичная, внутренняя и конфиденциальная.

2.2. Публичная информация предназначена для раскрытия (сайт, пресс-релизы). Внутренняя информация доступна только работникам Компании. Конфиденциальная информация (персональные данные, финансовая отчётность, договоры с клиентами) доступна ограниченному кругу лиц по списку, утверждённому начальником службы ИБ.

2.3. Конфиденциальные документы маркируются грифом "Конфиденциально" и передаются только по защищённым каналам, согласованным со службой ИБ.

2.4. Хранение конфиденциальной информации на личных устройствах, в личных облачных сервисах и мессенджерах запрещено.

3. Пароли и аутентификация

3.1. Длина пароля к корпоративным системам составляет не менее 12 символов. Пароль должен содержать строчные и прописные буквы, цифры и хотя бы один специальный символ.

3.2. Пароль необходимо менять каждые 90 дней. Повторное использование последних 5 паролей запрещено.

3.3. После 5 неудачных попыток ввода пароля учётная запись блокируется на 15 минут. Для досрочной разблокировки работник обращается в службу ИТ-поддержки.

3.4. Двухфакторная аутентификация обязательна для подключения к корпоративной сети через VPN, а также для доступа к почте и системе учёта

кадров.

3.5. Запрещено передавать пароли другим лицам, записывать их на бумаге в доступных местах и хранить в открытом виде в файлах и заметках.

4. Рабочее место и устройства

4.1. Экран рабочего компьютера блокируется автоматически через 5 минут бездействия. Покидая рабочее место, работник обязан заблокировать экран вручную.

4.2. Использование USB-носителей разрешено только тем, которые выданы ИТ-отделом и зарегистрированы в журнале учёта. Подключение личных носителей к рабочим компьютерам запрещено.

4.3. Установка программного обеспечения выполняется только отделом ИТ. Самостоятельная установка программ, не входящих в утверждённый перечень, запрещена.

4.4. Корпоративные ноутбуки оснащаются шифрованием диска. При утере или краже устройства работник обязан немедленно сообщить об этом в службу ИБ.

4.5. Документы, содержащие конфиденциальную информацию, не оставляются на столе по окончании рабочего дня, а бумажные копии уничтожаются в шредере.

5. Электронная почта и защита от фишинга

5.1. Корпоративная почта используется только для рабочих целей. Пересылка рабочих писем на личные адреса запрещена.

5.2. При получении подозрительного письма (неожиданное вложение, просьба срочно перейти по ссылке или сообщить пароль) работник не открывает вложения и пересылает письмо на адрес phishing@severnyveter.example.

5.3. Если работник уже перешёл по подозрительной ссылке или ввёл пароль на сторонней странице, он обязан немедленно сменить пароль и сообщить об этом в службу ИБ как об инциденте.

5.4. Раз в квартал служба ИБ проводит учебную фишинговую рассылку. Результаты используются для планирования дополнительного обучения.

6. Инциденты информационной безопасности

6.1. Инцидентом считается любое событие, которое привело или могло привести к утечке, потере или искажению информации: потеря устройства, взлом учётной записи, заражение вредоносным ПО.

6.2. О любом инциденте работник обязан сообщить в службу ИБ в течение 1 часа с момента обнаружения - по почте security@severnyveter.example или по внутреннему телефону 112.

6.3. Начальник службы ИБ организует расследование и в течение 5 рабочих дней готовит заключение о причинах инцидента и мерах по предотвращению повторения.

6.4. Скрытие инцидента является грубым нарушением Политики и влечёт дисциплинарную ответственность вплоть до увольнения.

7. Резервное копирование и журналы

7.1. Резервные копии корпоративных систем создаются ежедневно в 02:00 и хранятся 30 дней. Восстановление данных из резервной копии выполняется по заявке в ИТ-отдел.

7.2. Журналы доступа к конфиденциальным системам хранятся 180 дней и могут быть использованы при расследовании инцидентов.

7.3. Документы, над которыми ведётся работа, хранятся на корпоративном файловом хранилище, а не на локальном диске компьютера.

8. Доступ при приёме и увольнении

8.1. Доступ к системам выдаётся новому работнику в первый рабочий день по заявке руководителя. Объём доступа определяется должностью и принципом минимальных необходимых прав.

8.2. При увольнении работника все его доступы отзываются в течение 1 рабочего дня после последнего рабочего дня. Работник сдаёт корпоративные устройства и носители по акту.

8.3. Доступы руководителей и работников с правами администратора пересматриваются службой ИБ не реже одного раза в 6 месяцев.

9. Ответственность

9.1. Нарушение требований Политики влечёт дисциплинарную ответственность в соответствии с трудовым законодательством, а при причинении ущерба - материальную ответственность.

9.2. Контроль исполнения Политики осуществляет начальник службы ИБ. Раз в год он отчитывается о состоянии информационной безопасности перед генеральным директором.